PROTOTYPE 2 / PRIVACY MIDDLEWARE FOR AI AGENTS

VEIL GUARD

Protect the tool boundary.
Keep the answer useful.

AI agents often carry personal values from a user message into a tool request. Veil detects selected patterns locally, replaces matches with reversible task-scoped tokens, verifies the exact outgoing payload, and restores known values on the trusted return path.

THE PROBLEM	THE CHANGE IN PROTOTYPE 2
Sensitive values can cross the agent-to-tool boundary and appear in tool logs or responses.	An end-to-end agent workflow now shows the protected prompt, validated tool proposal, exact local helpdesk receipt, tokenized reply, trusted restoration, and final answer.

A local-first prototype with an optional networked Gemini agent and a simulated local helpdesk.

TEAM ASTRA

Ahmed Ghannam / Backend
Muhammed Ibrahim / PII detection
Syed Firas / Presentation and research

Anjuman Institute of Technology and Management

One run. One visible trust boundary.

React chat and the six-step workflow page use the same FastAPI run ID and recorded events.

1. **Synthetic ticket intake**
   React accepts only a ticket that exists in the local helpdesk. The current seeded ticket is TICKET-DEMO-1042.

2. **Protect model input**
   Veil scans locally and tokenizes selected values before an optional Gemini request. The backend, not the browser, holds the provider credential.

3. **Propose and validate**
   Gemini may propose one allowlisted helpdesk lookup. SDK auto-execution is disabled; the application validates the tool name and arguments.

4. **Gate tool egress**
   Veil recursively scans the prepared payload, applies task-scoped tokens, and verifies the exact outgoing copy. A residual match blocks dispatch.

5. **Local simulated helpdesk**
   The tool captures the exact protected receipt. Its response may contain tokens; no real external helpdesk is connected.

6. **Restore trusted answer**
   Veil checks protected result context before Gemini sees it, restores known tokens locally, and returns the answer to the user.

WHEN GEMINI IS UNAVAILABLE

Provider errors, connection loss, rejected credentials, exhausted quota, or missing local configuration produce a labeled deterministic fallback in the same run. If the final-answer request fails, fallback reuses the existing tool result and does not call the helpdesk twice.

Trust boundary: the local application owns detection, token mapping, validation, egress checks, and restoration. Gemini is optional and receives protected context. Tokens are reversible pseudonyms, not encryption.

Measured on synthetic data.

Two fixed datasets cover 11 selected entity types. Exact-span scoring and an independent scan of the captured simulated-tool receipt provide separate evidence.

100%	0	100%	0 calls
Held-out recall **26 / 26 planted spans**	**Planted literals** **at either receipt**	**Token occurrences** **restored**	**Blocked-path** **tool dispatches**

Detection and latency

SPLIT	CASES / PLANTED	TP / FP / FN	PRECISION / RECALL / F2	P50 / P95
Development	33 / 49	49 / 2 / 0	96.08% / 100% / 99.19%	0.129 / 0.349 ms
Held out	26 / 26	26 / 2 / 0	92.86% / 100% / 98.48%	0.117 / 0.251 ms

Latency measures only local gateway sanitization plus egress verification. Each case used 20 warm-ups and 100 timed samples. Gemini, network time, tool execution, and response restoration are excluded. Runtime: Python 3.12.14 on Windows 11 x64. Re-measure on the judging machine.

What the test means

The benchmark checks selected patterns in synthetic natural-language and nested JSON examples, including repeated values, varied formatting, and benign lookalikes. The held-out set is a fixed repository corpus, not an external or blinded evaluation. Recall is 100% only for the planted examples in these files.

The two phone false positives in each split came from benign numeric lookalikes. This shows the trade-off of broad phone matching. Detection can miss arbitrary names, unfamiliar formats, misspellings, or obscured values.

Demo evidence

The local demo records the exact payload received by the simulated helpdesk. Independent planted-value scanning found zero exact literals in those receipts. A separate intentional detector-miss path was blocked before dispatch, with zero tool calls and zero receipts. The workflow event stream and evidence page are tied to one run ID.

Built for a clear, testable demo.

Prototype 2 connects the privacy gateway to an agent workflow and makes the boundary inspectable.

What is implemented

COMPONENT	CURRENT IMPLEMENTATION
Detection	Python recognizers for EMAIL, PHONE_NUMBER, PERSON, STUDENT_ID, AADHAAR, BANK_ACCOUNT, UPI_ID, PAYMENT_CARD, PAN, IFSC, and IBAN.
Protection	Recursive payload scan, task-scoped reversible token vault, exact egress verification, and fail-closed blocking.
Agent and API	Deterministic offline agent, optional Gemini adapter, validated tool proposal, FastAPI run snapshots, and replayable SSE events.
User interface	React chat plus an animated six-step CSS/SVG and Motion trace for the same run. Streamlit remains a deterministic fallback and includes a nested JSON example.
Tool	Local simulated helpdesk with a single seeded ticket, TICKET-DEMO-1042. No production system or real support data is connected.

How to show it

1. Start the FastAPI backend and React frontend. 2. Submit a fictional request naming TICKET-DEMO-1042. 3. Open the same run's workflow link. 4. Point to the tokenized prompt when Gemini succeeds, or the labeled local fallback when it is unavailable. 5. Show Veil's egress result, the exact protected helpdesk receipt, tokenized tool response, restored response, and final answer.

Limits and next work

This is a selected-pattern prototype, not universal PII detection. Tokens are reversible pseudonyms held in a task-scoped in-memory vault; they are not encryption or production key management. The simulated helpdesk is local. Gemini makes an external request with protected synthetic context, but a fresh successful live Gemini browser run has not been verified for this submission. Focused Python and frontend checks pass; the full Python suite stalled in a Windows AppTest environment and is not claimed as passing.

Next work: broader and independently reviewed benchmarks, stronger person-name recognition, production-grade vault/session design, and live verification on the judging machine.

TEAM ASTRA
Ahmed Ghannam - Backend | Muhammed Ibrahim - PII detection | Syed Firas - Presentation and research
Anjuman Institute of Technology and Management